d) A JWT can have a limited expiry time reducing the risk if it is stolen.

e) JWT bearer authentication avoids sending a long-lived secret over the network.

## 11.4 Mutual TLS authentication

JWT bearer authentication is more secure than sending a client secret to the AS, but as you've seen in section 11.3.1 it can be significantly more complicated for the client. OAuth2 requires that connections to the AS are made using TLS, and you can use TLS for secure client authentication as well. In a normal TLS connection, only the server presents a certificate that authenticates who it is. As explained in chapter 10, this is all that is required to setup a secure channel as the client connects to the server and so the client needs to be assured that it has connected to the right server and not a malicious fake. But TLS also allows the client to optionally authenticate with a client certificate, allowing the server to be assured of the identity of the client and use this for access-control decisions. You can use this capability to provide secure authentication of service clients. When both sides of the connection authenticate, this is known as *mutual TLS* (mTLS).

> **TIP** Although it was once thought that client certificate authentication could be used for users, perhaps even replacing passwords, it is very seldom used. The complexity of managing keys and certificates makes the user experience very poor and confusing. Modern user authentication methods such